

Universidad de las Fuerzas Armadas ESPE

Sede Sangolquí

Carrera: Ingeniería de Software

NRC: [completar]

Laboratorio 1 – Unidad 1: Ataque de *phishing*

Suplantación de marca y captura de datos mediante un sitio clonado y un enlace acortado

Integrantes:

Marcelo Acuña

Abner Arboleda

Zaith Manangón

Andrés Cedeño

Materia: Ingeniería de Seguridad del Software

Docente: Milton Arguello

Sangolquí, 16 de octubre de 2026

Índice

Aviso de uso académico **2**

1. Tema **2**

2. Objetivo **2**

2.1. Objetivo general 2

2.2. Objetivos específicos 2

3. Antecedentes **3**

3.1. Herramientas utilizadas y su funcionalidad 3

3.2. Amenaza 3

3.3. Vulnerabilidad 3

3.4. Riesgo 4

3.5. Técnicas empleadas 4

3.6. Conducta o comportamiento humano relacionado 4

4. Desarrollo **4**

4.1. El correo (vector de entrega) 5

4.2. Configuración del servidor y del sitio web 5

4.3. Uso del acortador de URL (Bitly) 7

5. Resultados **8**

5.1. Captura del direccionamiento desde el teléfono o el clic 8

5.2. Simulación del ingreso de datos 9

6. Conclusiones **9**

7. Recomendaciones **10**

Anexos **10**

Aviso de uso académico

El presente trabajo documenta un ejercicio controlado de concientización sobre *phishing*, realizado con fines exclusivamente educativos dentro de la materia de Seguridad. El sitio recreado y el enlace acortado se construyeron en un entorno de laboratorio, no se difundieron a víctimas reales y no se recolectaron datos de personas sin su conocimiento. El objetivo es comprender cómo opera este ataque para poder **detectarlo y prevenirlo**. Reproducir estas técnicas contra terceros sin autorización constituye un delito.

1. Tema

Ataque de *phishing*: suplantación de la identidad de una marca de confianza (Primax) para inducir a la víctima a entregar sus datos personales a través de un sitio web clonado, difundido mediante un correo electrónico y un enlace acortado.

2. Objetivo

2.1. Objetivo general

Simular, en un entorno de laboratorio controlado, un ataque de *phishing* por suplantación de marca que combine un sitio web clonado y un enlace acortado, con el fin de comprender el funcionamiento técnico y el componente humano del ataque y derivar medidas de detección y prevención.

2.2. Objetivos específicos

- Identificar las herramientas utilizadas (Vercel, Supabase y Bitly) y describir su funcionalidad dentro del ataque.
- Analizar la amenaza, la vulnerabilidad y el riesgo asociados, así como las técnicas de engaño y el comportamiento humano que explota el *phishing*.
- Construir y publicar un sitio web que imite una promoción de Primax y capturar los datos ingresados en una base de datos.
- Difundir el enlace del sitio mediante un acortador de URL que simule el vector de entrega.
- Evidenciar el redireccionamiento del enlace desde un teléfono y la simulación del ingreso de datos por parte de la víctima.

- Proponer conclusiones y recomendaciones orientadas a la detección y prevención del ataque.

3. Antecedentes

El *phishing* es una técnica de ingeniería social en la que un atacante se hace pasar por una entidad legítima para engañar a la víctima y obtener información sensible o inducirla a realizar una acción perjudicial. Según el *Anti-Phishing Working Group* (APWG), continúa siendo uno de los vectores de ataque más frecuentes, debido a que explota al eslabón más débil de la cadena de seguridad: el ser humano apwg2024, nistphishing.

3.1. Herramientas utilizadas y su funcionalidad

Cuadro 1. Herramientas empleadas en el laboratorio y su función en el ataque.

Herramienta	**Funcionalidad dentro del ataque**
Vercel	Plataforma de alojamiento que publica el sitio web clonado en una URL con HTTPS y ejecuta la función *serverless* que recibe los datos del formulario. Da al sitio apariencia profesional y disponibilidad inmediata.
Supabase	Base de datos como servicio (PostgreSQL). Almacena los datos capturados en la tabla `participantes`. La función del servidor inserta los registros mediante su API REST.
Bitly	Acortador de URL. Transforma la dirección real del sitio en un enlace corto y de apariencia inofensiva, ocultando el dominio de destino y permitiendo medir los clics. Es el vector de entrega del enlace hacia la víctima.
HTML, CSS y JavaScript	Tecnologías con las que se recreó la interfaz del sitio legítimo (clon visual) y el formulario de captura.
Python	Lenguaje de la función *serverless* (`api/participantes.py`) que valida y reenvía los datos a Supabase.

3.2. Amenaza

La amenaza es un atacante que suplanta a una marca reconocida (Primax) para engañar a usuarios y robar sus datos personales. Al tratarse de una empresa de consumo masivo, la marca genera confianza y amplía el número de posibles víctimas.

3.3. Vulnerabilidad

La vulnerabilidad principal no es técnica sino humana: la tendencia de las personas a confiar en marcas conocidas, a actuar con rapidez ante un supuesto premio y a no verificar la

dirección real de un enlace, especialmente en el teléfono. A ello se suma que los acortadores ocultan el destino real de la URL, dificultando que el usuario detecte el engaño antes de hacer clic.

3.4. Riesgo

El riesgo es la exposición y el robo de datos personales (nombres, apellidos, número de teléfono y correo electrónico). Con esa información, el atacante puede realizar suplantación de identidad, fraude, envío de *spam*, llamadas fraudulentas o ataques dirigidos (*spear phishing*) más convincentes en una segunda etapa.

3.5. Técnicas empleadas

- **Suplantación de marca (*brand impersonation*):** uso del logotipo, colores y lenguaje de Primax para aparentar legitimidad.
- **Pretexto de premio y urgencia:** un supuesto sorteo de "un año de gasolina gratis" que motiva a actuar rápido sin reflexionar.
- **Clonado de sitio web:** recreación visual de una página promocional con un formulario de captura de datos.
- **Enlace acortado:** uso de Bitly para disimular el dominio real de destino y entregar el enlace a la víctima.
- **Homógrafos / homóglifos:** uso de caracteres de apariencia similar en la dirección (por ejemplo, una letra cirílica que imita una latina) para reforzar el parecido con un enlace legítimo.

3.6. Conducta o comportamiento humano relacionado

El ataque explota principios de influencia psicológica descritos por cialdini2001: la *autoridad* y la *confianza* en una marca conocida, la *escasez* y la *urgencia* de un premio por tiempo limitado y la *codicia* ante un beneficio gratuito. Estos sesgos reducen el pensamiento crítico y llevan a la víctima a entregar sus datos sin verificar la autenticidad del mensaje ni del enlace.

4. Desarrollo

El ataque simulado sigue el flujo de la Figura 1: la víctima recibe el correo, abre el enlace acortado, llega al sitio clonado alojado en Vercel, ingresa sus datos y estos se almacenan en Supabase.

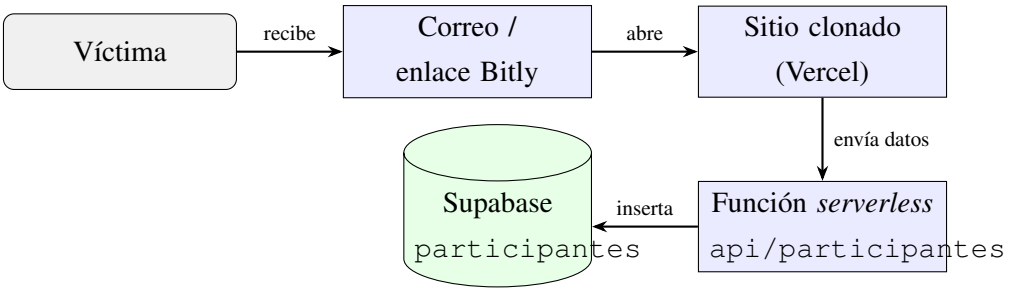
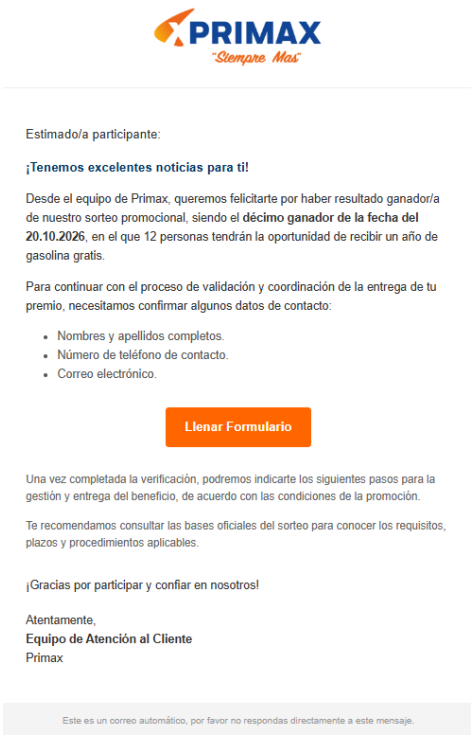


Figura 1. Arquitectura del ataque de *phishing* simulado.

4.1. El correo (vector de entrega)

El mensaje imita una comunicación oficial de Primax. Felicita a la víctima por haber resultado "ganadora" de un sorteo y le pide confirmar sus datos de contacto (nombres, teléfono y correo) a través de un botón *Llenar Formulario*, que enlaza al sitio clonado. El tono institucional, el logotipo y la nota de "correo automático, no responda" refuerzan la apariencia de legitimidad.


PRIMAX
"Siempre Mas"

Estimado/a participante:

¡Tenemos excelentes noticias para ti!

Desde el equipo de Primax, queremos felicitarte por haber resultado ganador/a de nuestro sorteo promocional, siendo el **décimo ganador de la fecha del 20.10.2026**, en el que 12 personas tendrán la oportunidad de recibir un año de gasolina gratis.

Para continuar con el proceso de validación y coordinación de la entrega de tu premio, necesitamos confirmar algunos datos de contacto:

- Nombres y apellidos completos.
- Número de teléfono de contacto.
- Correo electrónico.

Llenar Formulario

Una vez completada la verificación, podremos indicarte los siguientes pasos para la gestión y entrega del beneficio, de acuerdo con las condiciones de la promoción.

Te recomendamos consultar las bases oficiales del sorteo para conocer los requisitos, plazos y procedimientos aplicables.

¡Gracias por participar y confiar en nosotros!

Atentamente,
Equipo de Atención al Cliente
Primax

Este es un correo automático, por favor no respondas directamente a este mensaje.

Figura 2. Correo utilizado como vector de entrega.

4.2. Configuración del servidor y del sitio web

El sitio es una página estática (HTML, CSS y JavaScript) que recrea una promoción de Primax titulada "La Súper Tanqueada del Año". Contiene un formulario que solicita nombres, apellidos, teléfono y correo. Al enviarse, el formulario realiza una petición `POST` a la ruta

`/api/participantes` mediante `fetch`.

El proyecto se publicó en **Vercel**, que sirve la página estática y ejecuta la función *serverless* `api/participantes.py`. Esta función valida los campos recibidos (campos obligatorios, longitudes máximas y formato de correo) y, si son correctos, los reenvía a Supabase a través de su API REST. Las credenciales de Supabase (`SUPABASE_URL` y `SUPABASE_ANON_KEY`) se configuran como variables de entorno en Vercel y nunca se exponen en el navegador.

El enlace de publicación del sitio es:

https://primaxsiempremas.vercel.app/

En **Supabase** se creó la tabla `participantes` con una política de seguridad a nivel de fila (RLS) que únicamente permite insertar registros, sin exponer una ruta pública de lectura. El Código 1 muestra su definición.

Código 1. Definición de la tabla en Supabase (`supabase-schema.sql`).

```sql
create table public.participantes (
  id bigint generated by default as identity primary key,
  nombres text not null check (char_length(nombres) between 1 and
   100),
  apellidos text not null check (char_length(apellidos) between 1 and
    100),
  telefono text not null check (char_length(telefono) between 1 and
   30),
  correo text not null check (char_length(correo) between 3 and 254),
  creado_en timestamptz not null default now()
);

alter table public.participantes enable row level security;

create policy "Permitir registrar participantes"
on public.participantes
for insert
to anon
with check (true);
```



Figura 3. Sitio web clonado publicado en Vercel.

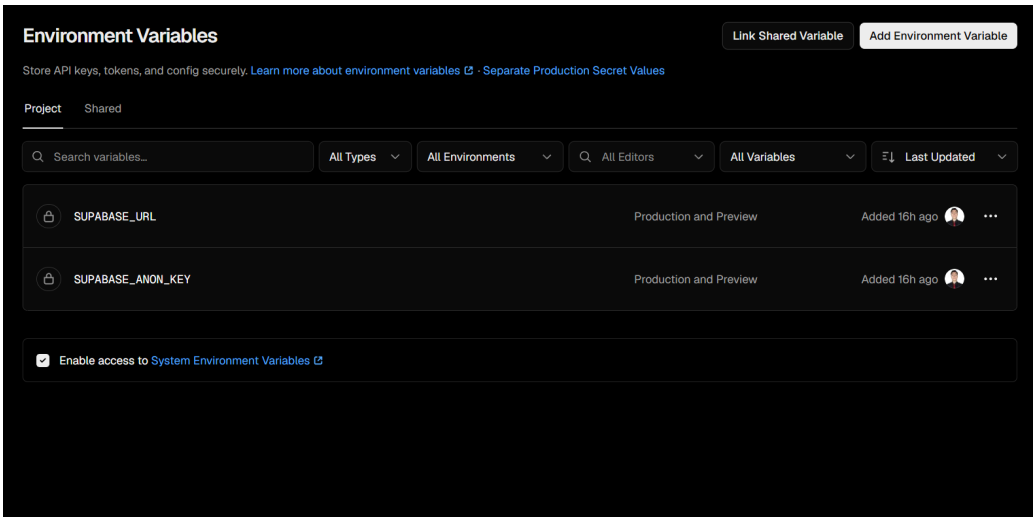


Figura 4. Configuración de variables de entorno en Vercel.

4.3. Uso del acortador de URL (Bitly)

La dirección del sitio se acortó con Bitly para ocultar el dominio real y dar al enlace una apariencia más confiable. El enlace acortado utilizado fue:

`https://bit.ly/primaÑĚ`

Además de disimular el destino, el acortador permite al atacante registrar cuántas personas hicieron clic. En este enlace se aprecia también la técnica de **homóglifos**: el último carácter es una letra de apariencia idéntica a la latina, lo que dificulta distinguir el enlace de uno legítimo.

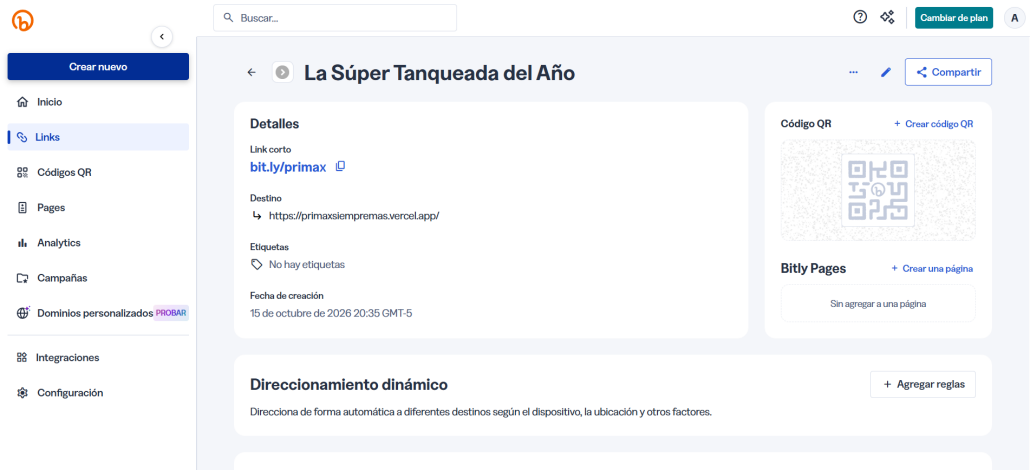
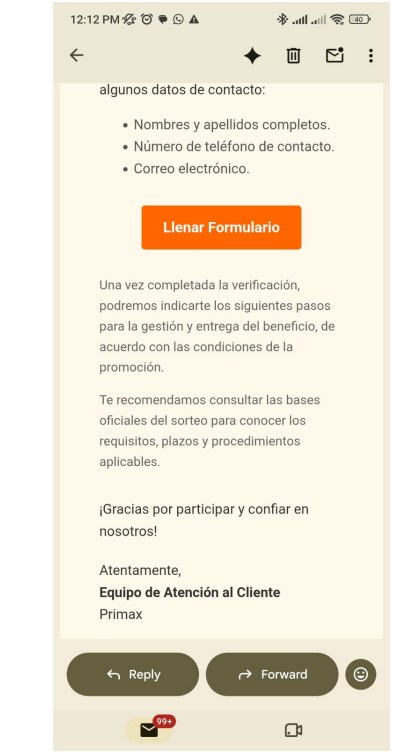


Figura 5. Acortamiento del enlace con Bitly.

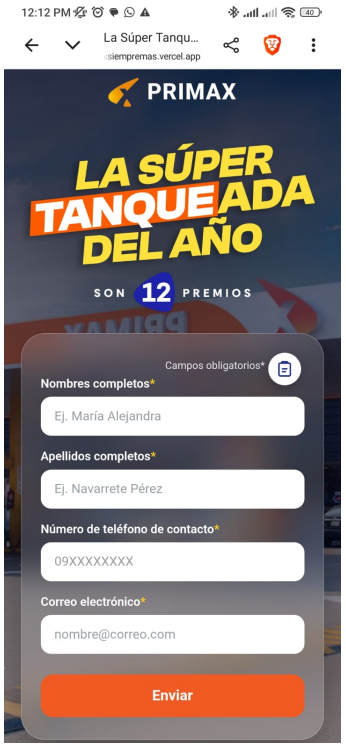
5. Resultados

5.1. Captura del direccionamiento desde el teléfono o el clic

Al pulsar el enlace acortado desde un teléfono, el navegador redirige a la víctima al sitio clonado alojado en Vercel. La Figura 6 evidencia este redireccionamiento: el enlace corto conduce al sitio de la "promoción" sin que la URL real sea evidente para el usuario.



(a) Clic en el enlace desde el teléfono

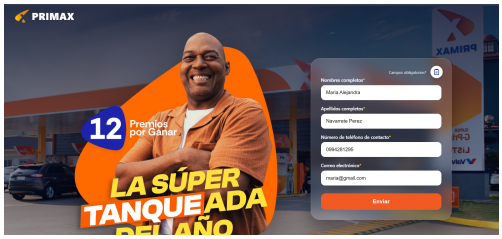


(b) Sitio cargado en el móvil

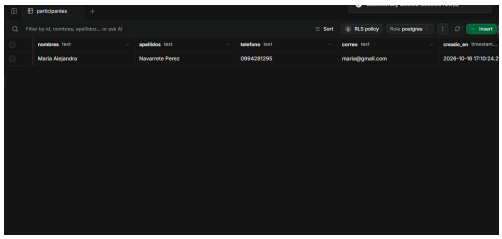
Figura 6. Redireccionamiento del enlace desde el teléfono.

5.2. Simulación del ingreso de datos

Para simular el comportamiento de una víctima, se completó el formulario con datos de prueba y se envió. La función del servidor validó los campos y los almacenó en Supabase. La Figura 7 muestra el formulario diligenciado y el registro resultante en la tabla `participantes`.



(a) Formulario diligenciado



(b) Dato capturado en Supabase

Figura 7. Simulación del ingreso y captura de datos.

El resultado confirma que el flujo completo del ataque funciona: entrega (correo / enlace acortado) → redireccionamiento al sitio clonado → captura de datos → almacenamiento en la base de datos.

6. Conclusiones

1. El ejercicio demostró que un ataque de *phishing* convincente no requiere técnicas avanzadas de intrusión: con herramientas gratuitas y de uso legítimo (Vercel, Supabase y Bitly) se puede construir y publicar en poco tiempo un sitio que suplanta a una marca y captura datos reales.

2. La eficacia del ataque descansa en el factor humano. La suplantación de una marca de confianza, el pretexto de un premio y la urgencia reducen el pensamiento crítico de la víctima, que entrega sus datos sin verificar el remitente ni la dirección real del enlace.

3. El uso combinado de un enlace acortado y caracteres homóglifos oculta el dominio de destino y hace que el engaño sea especialmente difícil de detectar en dispositivos móviles, donde la URL no se inspecciona con facilidad.

4. Documentar el ataque de principio a fin permite comprender cada etapa del flujo y, sobre todo, identificar los puntos en los que una persona informada puede detenerlo: la verificación del remitente, la inspección del enlace y la desconfianza ante solicitudes de datos no esperadas.

7. Recomendaciones

1. **Verificar el remitente y la URL:** desconfiar de correos no solicitados que anuncian premios y comprobar la dirección real del enlace antes de abrirlo; las empresas legítimas no piden datos personales por estos medios.
2. **Precaución con enlaces acortados:** previsualizar el destino de un enlace corto antes de abrirlo, ya que oculta la dirección real a la que redirige.
3. **Observar las señales de homóglifos:** prestar atención a caracteres extraños o sustituidos en las direcciones y a pequeñas diferencias en el dominio.
4. **No entregar datos personales en formularios no verificados** y acceder a las promociones únicamente desde los canales oficiales de la empresa escribiendo la dirección directamente.
5. **Capacitación y concientización:** realizar campañas periódicas de concientización y simulacros controlados de *phishing* dentro de las organizaciones para entrenar al personal en la detección de estos ataques.
6. **Medidas técnicas de defensa:** habilitar filtros antispam, autenticación de correo (SPF, DKIM, DMARC), autenticación multifactor (MFA) y reportar los sitios fraudulentos para su bloqueo.

Anexos

Anexo A: Recursos del laboratorio

- Sitio publicado (entorno de laboratorio): https://primaxsiempremas.vercel.app/
- Enlace acortado de entrega: https://bit.ly/primaÑĚ

Referencias

[APWG(2024)] Anti-Phishing Working Group. (2024). *Phishing Activity Trends Report*. APWG. https://apwg.org/trendsreports/

[Cialdini(2001)] Cialdini, R. B. (2001). *Influence: Science and practice* (4.ª ed.). Allyn & Bacon.

[NIST(s.f.)] National Institute of Standards and Technology. (s.f.). *Phishing*. NIST. https://www.nist.gov/itl/smallbusinesscyber/guidance-topic/phishing

[Supabase(s.f.)] Supabase. (s.f.). *Supabase documentation*. https://supabase.com/docs

[Vercel(s.f.)] Vercel. (s.f.). *Vercel documentation*. https://vercel.com/docs